

Threat Model: IAM Least-Privilege Policy

1. Objective

Identify the risks introduced by an overly permissive IAM policy attached to a low-trust principal (an intern account), redesign that policy following least-privilege principles, and validate the redesign through simulated policy evaluation before deployment.

2. Assets

Asset	Description	Sensitivity
S3 buckets	intern-project-bucket (working data); other buckets in the account including finance-payroll-bucket	Medium–High
EC2 instances	Compute instances in the account, including production workloads	High
IAM identities & roles	intern_user credentials, access keys, and higher-privileged roles reachable via PassRole	Critical

3. Threats

Threat	Vector	Impact
Privilege escalation via misconfigured roles	Wildcard iam:* / iam:PassRole and iam:CreateAccessKey grants let a low-trust principal attach policies to itself or pass an admin role to a service it controls	Full account takeover
Data exposure / exfiltration	s3:* on Resource:* allows reading, and s3:PutBucketPolicy allows re-sharing, any bucket in the account -- not just the intern's own project bucket	Leak of sensitive or unrelated business data (e.g. payroll)
Destructive action / availability loss	s3:DeleteBucket and ec2:TerminateInstances are permitted with no resource scoping	Data loss, production outage
Lateral movement	Broad ec2:* combined with iam:PassRole lets a compromised low-privilege credential pivot into compute and higher-privileged execution contexts	Expanded blast radius from a single compromised credential
Credential compromise amplification	No MFA condition on sensitive actions means a single leaked static credential is sufficient to act	Low attacker cost to exploit a leaked key

4. Mitigations (Applied in Redesigned Policy)

Mitigation	Implementation	Threat(s) Addressed
Scoped policies (resource restriction)	s3:GetObject / s3:ListBucket restricted to arn:aws:s3:::intern-project-bucket and its objects only, instead of Resource: *	Data exposure, destructive action

Action restriction	s3:* replaced with only the two read actions the intern needs; ec2:* replaced with Describe-only actions	Destructive action, lateral movement
MFA enforcement	Condition block requires aws:MultiFactorAuthPresent = true before S3 read access is granted	Credential compromise amplification
Explicit deny on escalation actions	Deny statement blocks iam:CreateAccessKey, iam:AttachUserPolicy, iam:PassRole, iam:PutUserPolicy, iam:AttachRolePolicy regardless of any other Allow statement added later	Privilege escalation via misconfigured roles
Region / context conditions	EC2 describe permissions scoped with a Condition restricting ec2:Region to the intern's assigned region	Lateral movement, blast-radius reduction

5. Validation Summary (Simulation Results)

Both the original (“before”) and redesigned (“after”) policies were evaluated against nine representative test actions using a local IAM policy-evaluation simulator that implements the same decision logic as **aws iam simulate-principal-policy** (explicit deny > allow > implicit deny). Full CLI-style output is provided in `simulation_output.log`.

Test Action	Before	After
s3:GetObject on approved bucket (MFA present)	Allowed	Allowed
s3:GetObject on approved bucket (no MFA)	Allowed	Denied (implicit)
s3:GetObject on unrelated payroll bucket	Allowed	Denied (implicit)
s3:DeleteBucket on approved bucket	Allowed	Denied (implicit)
s3:PutBucketPolicy on approved bucket	Allowed	Denied (implicit)
ec2:DescribeInstances in allowed region	Allowed	Allowed
ec2:TerminateInstances	Allowed	Denied (implicit)
iam:CreateAccessKey (self-escalation)	Allowed	Denied (explicit)
iam:PassRole to admin role	Allowed	Denied (explicit)

Result: the before policy allowed all 9/9 tested actions, including bucket deletion, bucket-policy tampering, instance termination, and two distinct privilege-escalation paths. The redesigned policy allows only the 2 actions the intern legitimately needs and denies all 7 remaining test cases (2 explicit denies on escalation vectors, 5 implicit denies from removing wildcard grants and adding the MFA condition).